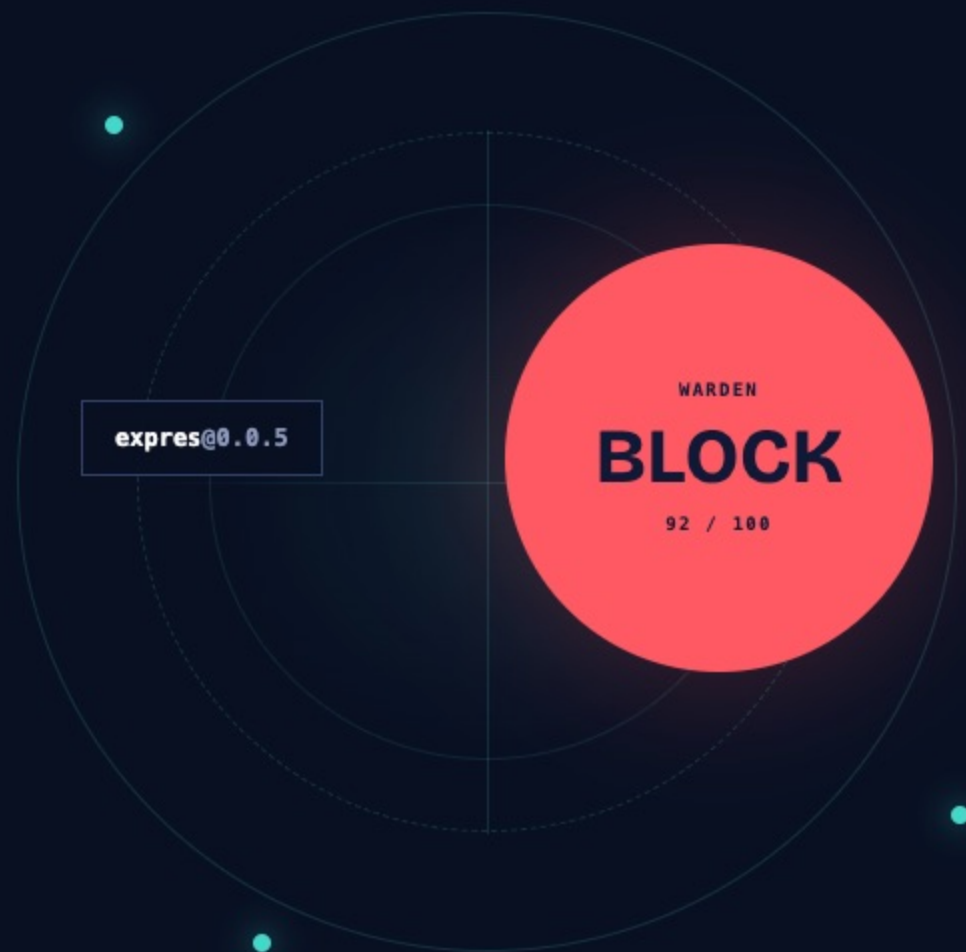


AGENT-FIRST PACKAGE SECURITY

# WARDEN

Nothing runs without a verdict.

```
$ npm install expres
```



# The package is the payload.



## THE CHECKPOINT

# One command enters. Evidence decides what leaves.



typosquat

install script

provenance downgrade

environment access

raw IP

LIVE PRODUCT

# warden check

• • • ~/project

• LIVE

```
$ warden check acme-http@1.0.1
resolving acme-http@1.0.1
✓ integrity verified    sha512
! release diff         postinstall added
! provenance           attestation removed
! code                 process.env → raw IP
BLOCK acme-http@1.0.1  risk 100 / 100
exit 20 · install never started
```

• BLOCKED BEFORE ANY SCRIPT RAN

NO HABIT CHANGE

# Warden intercepts the command.

npm

pnpm

yarn

bun



WARDEN



registry

transparent shim

LIVE

```
$ npm install express expres
```

```
Warden: vetting 2 packages before install
```

```
ALLOW express@5.1.0    clean
```

```
BLOCK expres@0.0.5      typosquat, install-script
```

```
install aborted · no lifecycle script executed
```

ONE-TIME SETUP

# Install once. Protect every manager.

✓ SHA-256

✓ 3 binaries

✓ 6 shims

✓ completions

• • • installer

• LIVE

up/down move, space toggles, enter confirms

↵ enter

When warden finds a risky package:

- 1) protect stop the install and show why (recommended)
- 2) observe never stop anything, just keep a record

choice [1]: 1

installed ~/.warden/bin/warden, wnpm, wnpv

shims npm pnpm yarn bun npx bunx

PATH added shims and binaries to ~/.zshrc

config ~/.warden/config.json (mode: brief, intercept: install+exec)

**IMPORTANT** interception is not active in this shell yet

activate exec zsh

verify warden check left-pad

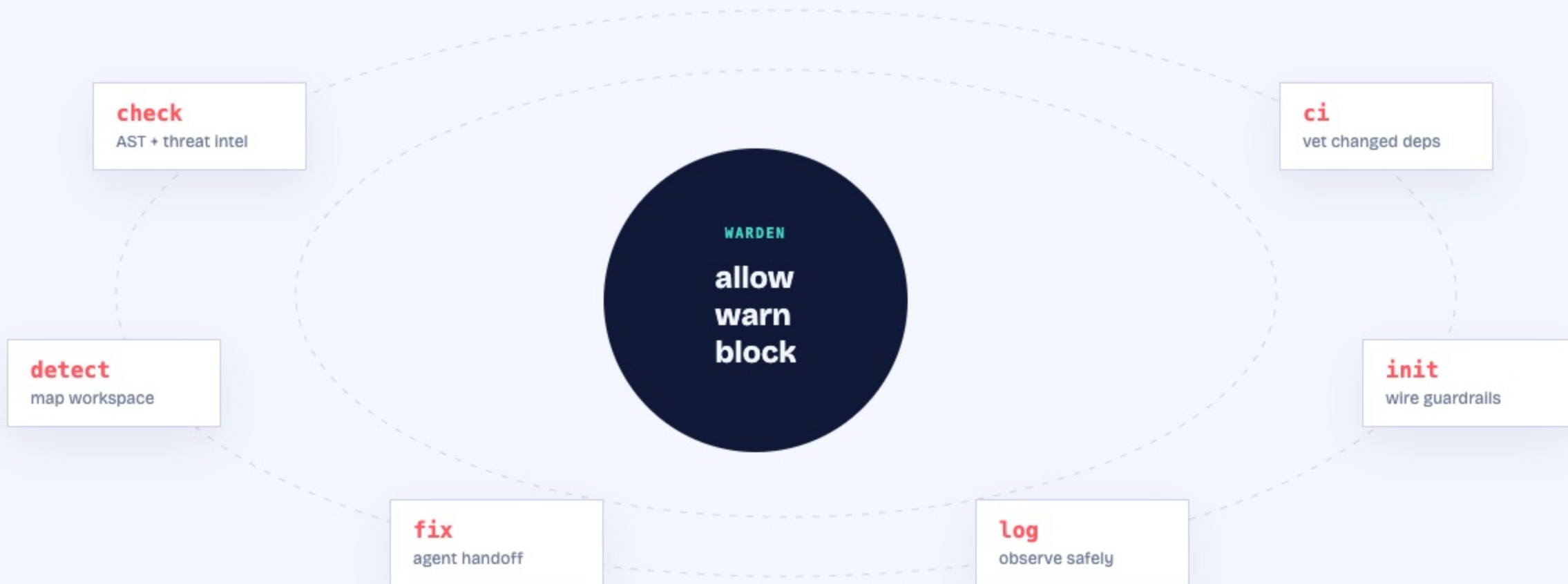
THE PRODUCT SURFACE

# One trust layer. Every workflow.

PROTECT OR OBSERVE

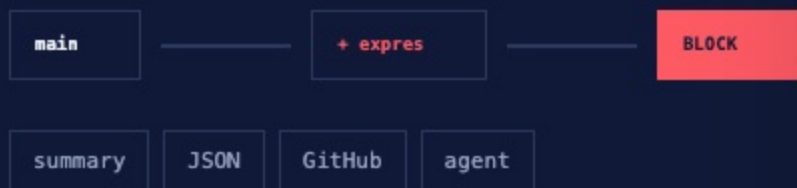
TYPED JSON

INTEGRITY CACHE



PULL REQUEST GATE

# warden ci



● ● ● pull request #142

● LIVE

```
$ warden ci --reporter agent
diff vs merge-base · 1 package changed
BLOCK expres@0.0.5 package.json:14
rule      typosquat
fix       replace expres with express
verify    warden ci --reporter agent
verdict block · exit 20
```

# Your agent gets evidence, a fix, and a finish line.

```
structured handoff • LIVE

wrote .warden/handoff.json
finding  expres@0.0.5 · typosquat
evidence 1 edit from express · postinstall added
fix      replace expres with express
verify   warden ci --reporter agent
launch   codex exec "Read .warden/handoff.json..."
$ codex exec "Read .warden/handoff.json and apply the fix"
updated  package.json · expres → express
$ warden ci --reporter agent
verdict  allow · exit 0
```



THREE INCIDENTS, ONE PATTERN

# Trust changed faster than defenders reacted.

SEP 2025

**2B+**

weekly downloads exposed

**chalk + debug**

18 poisoned packages

NOV 2025

**796**

infected npm packages

**Shai-Hulud 2.0**

1,092 affected versions

MAR 2026

**39m**

between poisoned releases

**axios**

cross-platform RAT

AXIOS MALICIOUS VERSIONS REMAINED LIVE

**about 3 hours**

WHAT COMES NEXT

# From package gate to repository shield.



CORE supply-chain coverage

NEXT repository policy

LATER MCP + organization view

THE OUTCOME

# Keep the workflow. Add the checkpoint.



## EVIDENCE

# Sources

---

01 CVE Program metrics

---

03 Sonatype 2026 report

---

05 Datadog Shai-Hulud 2.0

---

07 axios maintainer report

---

02 Verizon DBIR 2026

---

04 USENIX package hallucinations

---

06 Aikido chalk + debug

---

08 Reveal.js motion reference

Figures checked July 14, 2026. Later settled incident counts are used where available.